

Security Audit

Nebula (NFT MarketPlace)

Table of Contents

Executive Summary	4
Project Context	4
Audit Scope	7
Security Rating	8
Intended Smart Contract Functions	9
Code Quality	10
Audit Resources	10
Dependencies	10
Severity Definitions	11
Status Definitions	12
Audit Findings	13
Centralisation	15
Conclusion	16
Our Methodology	17
Disclaimers	19
About Hashlock	20

CAUTION

THIS DOCUMENT IS A SECURITY AUDIT REPORT AND MAY CONTAIN CONFIDENTIAL INFORMATION. THIS INCLUDES IDENTIFIED VULNERABILITIES AND MALICIOUS CODE WHICH COULD BE USED TO COMPROMISE THE PROJECT. THIS DOCUMENT SHOULD ONLY BE FOR INTERNAL USE UNTIL ISSUES ARE RESOLVED. ONCE VULNERABILITIES ARE REMEDIATED, THIS REPORT CAN BE MADE PUBLIC. THE CONTENT OF THIS REPORT IS OWNED BY HASHLOCK PTY LTD FOR USE OF THE CLIENT.

Executive Summary

The Nebula team partnered with Hashlock to conduct a security audit of their smart contracts. Hashlock manually and proactively reviewed the code in order to ensure the project's team and community that the deployed contracts are secure.

Project Context

Nebula is a digital-asset marketplace on the Nexa blockchain that allows users to mint, manage, and trade NFTs and tokens all in one place. Built on Nexa's high-throughput, Proof-of-Work Layer-1 infrastructure — known for its low fees, smart contract support, and scalability — Nebula provides creators with user-friendly tools and collectors with a seamless experience. Initially focused on NFTs, the platform now supports both non-fungible and fungible token trading, offering a dual marketplace. With accessible design, clear utility for token projects, and reliance on Nexa's resilient decentralised framework, Nebula aims to serve as a core hub for community, creators, and digital assets in the Nexa ecosystem.

Project Name: Nebula

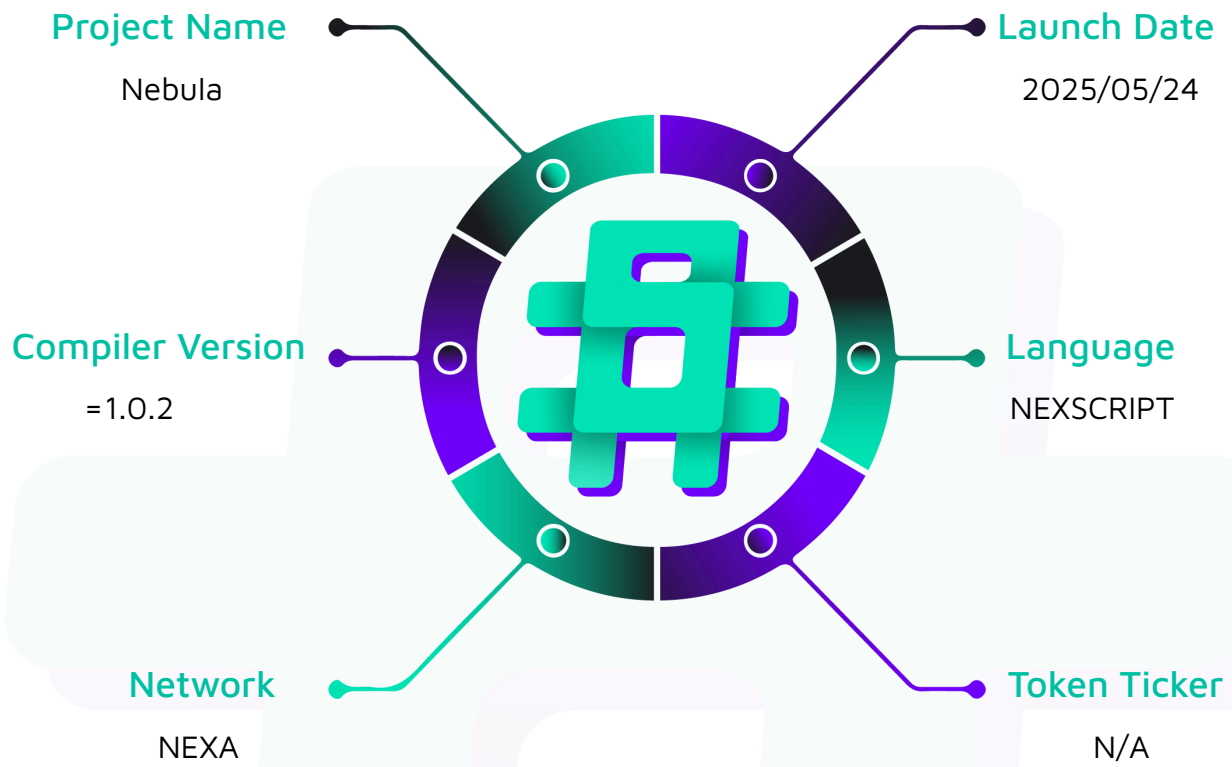
Project Type: NFT MarketPlace.

Compiler Version: =1.0.2

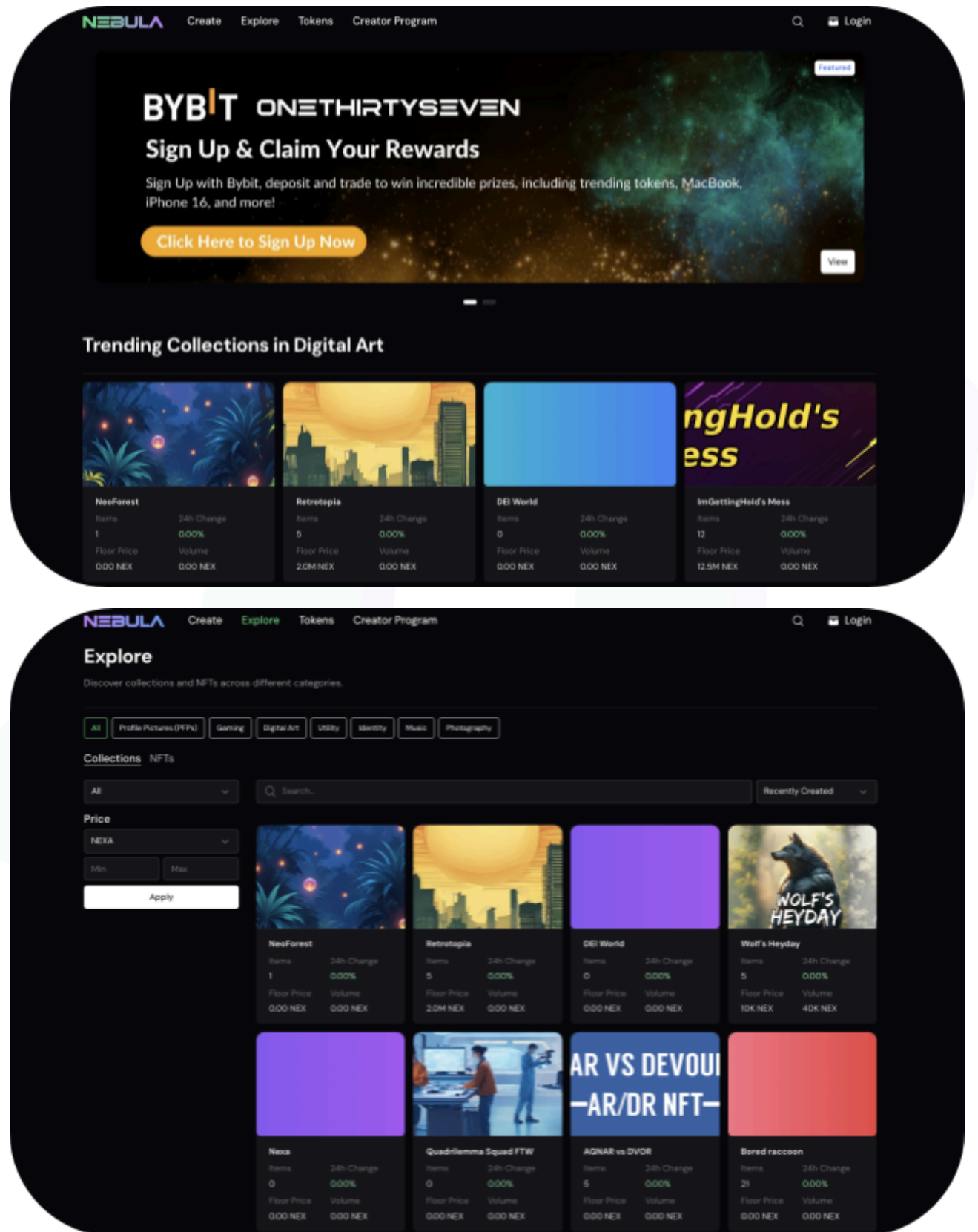
Website: <https://nebula.markets/>

Logo:

The logo for Nebula, featuring the word "NEBULA" in a bold, blue, sans-serif font. The letter "E" is stylized with three horizontal bars.

Visualised Context:

Project Visuals:



Audit Scope

We at Hashlock audited the NexScript code within the Nebula project, the scope of work included a comprehensive review of the smart contracts listed below. We tested the smart contracts to check for their security and efficiency. These tests were undertaken primarily through manual line-by-line analysis and were supported by software-assisted testing.

Description	Nebula Smart Contracts
Platform	Nexa / NexScript
Audit Date	August, 2025
Contract 1	buy_nft_for_nexa_v0.nex
Contract 1 MD5 Hash	1c5f00734909c44c9b49133dc38ad09c
Contract 2	buy_nft_for_nexa_v1.nex
Contract 2 MD5 Hash	1824295d2efe7a4f6fd213c73a619c81
Contract 3	sell_nft_for_nexa_v0.nex
Contract 3 MD5 Hash	4fbb56d4fa8e86648a318d665bf64525
Contract 4	sell_nft_for_nexa_v1.nex
Contract 4 MD5 Hash	5f6812dca53e454f10a142a5d44d8639
Fix Review GitHub Commit Hash	8e6a876d0cc796c3ea0020b1ea52bd5efb882f37

Security Rating

After Hashlock's Audit, we found the smart contracts to be **"Secure"**. The contracts all follow simple logic, with correct and detailed ordering.



The 'Hashlocked' rating is reserved for projects that ensure ongoing security via bug bounty programs or on chain monitoring technology.

All issues uncovered during automated and manual analysis were meticulously reviewed and applicable vulnerabilities are presented in the [Audit Findings](#) section. The list of audited assets is presented in the [Audit Scope](#) section and the project's contract functionality is presented in the [Intended Smart Contract Functions](#) section.

All vulnerabilities initially identified have now been resolved.

Hashlock found:

1 Low severity vulnerability

1 QA

Caution: *Hashlock's audits do not guarantee a project's success or ethics, and are not liable or responsible for security. Always conduct independent research about any project before interacting.*

Intended Smart Contract Functions

Claimed Behaviour	Actual Behaviour
buy_nft_for_nexa/ (v0 & v1) Allows a user (the Maker) to: - Create a standing buy-offer for any NFT from a specific collection by locking NEXA into the contract. - Cancel their buy-offer at any time to reclaim their locked NEXA. Allows another user (the Taker) to: - Fulfill the Maker's buy-offer by providing an NFT from the specified collection. - Receive the Maker's locked NEXA as payment, minus a fee sent to the marketplace.	Contract achieves this functionality.
sell_nft_for_nexa/ (v0 & v1) Allows a user (the Maker) to: - Create a fixed-price listing for an NFT by locking the asset into the contract. - Set a specific sale price in NEXA for the NFT. - Cancel their sell-offer at any time to reclaim their locked NFT. Allows another user (the Taker) to: - Purchase the NFT by providing the exact amount of NEXA specified by the Maker. - Receive the NFT from the contract.	Contract achieves this functionality.

Code Quality

This audit scope involves the smart contracts of the Nebula project, as outlined in the Audit Scope section. All contracts, libraries, and interfaces mostly follow standard best practices.

The code is very well commented on and closely follows best practice nat-spec styling. All comments are correctly aligned with code functionality.

Audit Resources

We were given the Nebula project smart contract code in the form of GitHub access.

As mentioned above, code parts are well commented. The logic is straightforward, and therefore it is easy to quickly comprehend the programming flow as well as the complex code logic. The comments are helpful in providing an understanding of the protocol's overall architecture.

Dependencies

As per our observation, the libraries used in this smart contracts infrastructure are based on well-known industry standard open source projects.

Apart from libraries, its functions are used in external smart contract calls.

Severity Definitions

The severity levels assigned to findings represent a comprehensive evaluation of both their potential impact and the likelihood of occurrence within the system. These categorizations are established based on Hashlock's professional standards and expertise, incorporating both industry best practices and our discretion as security auditors. This ensures a tailored assessment that reflects the specific context and risk profile of each finding.

Significance	Description
High	High-severity vulnerabilities can result in loss of funds, asset loss, access denial, and other critical issues that will result in the direct loss of funds and control by the owners and community.
Medium	Medium-level difficulties should be solved before deployment, but won't result in loss of funds.
Low	Low-level vulnerabilities are areas that lack best practices that may cause small complications in the future.
Gas	Gas Optimisations, issues, and inefficiencies.
QA	Quality Assurance (QA) findings are informational and don't impact functionality. Supports clients improve the clarity, maintainability, or overall structure of the code.

Status Definitions

Each identified security finding is assigned a status that reflects its current stage of remediation or acknowledgment. The status provides clarity on the handling of the issue and ensures transparency in the auditing process. The statuses are as follows:

Significance	Description
Resolved	The identified vulnerability has been fully mitigated either through the implementation of the recommended solution proposed by Hashlock or through an alternative client-provided solution that demonstrably addresses the issue.
Acknowledged	The client has formally recognized the vulnerability but has chosen not to address it due to the high cost or complexity of remediation. This status is acceptable for medium and low-severity findings after internal review and agreement. However, all high-severity findings must be resolved without exception.
Unresolved	The finding remains neither remediated nor formally acknowledged by the client, leaving the vulnerability unaddressed.

Audit Findings

Low

[L-01] Contracts - Unpinned Pragma Version

Description

The contract uses a floating pragma (`>= 1.0.2`). This can lead to the contract being compiled with different compiler versions, potentially producing different bytecode from the same source code. This practice complicates building reproducibility and makes it difficult to verify that the audited code is the same as the deployed code.

Recommendation

For improved code quality and deterministic builds, lock the pragma to the specific compiler version used for testing and deployment, for example: `pragma nexscript 1.0.2;`

Status

Resolved

QA

[Q-01] Contracts - Clarify that P2ST locking bytecode enforces token ID and amount; add token-sending examples in docs

Description

Readers expect an explicit tokenAmount check, but in Nexa P2ST the Script PubKey (locking bytecode) embeds both Group ID and Group Amount, so matching lockingBytecode already requires the correct token and amount, which is not clear in the current docs.

Recommendation

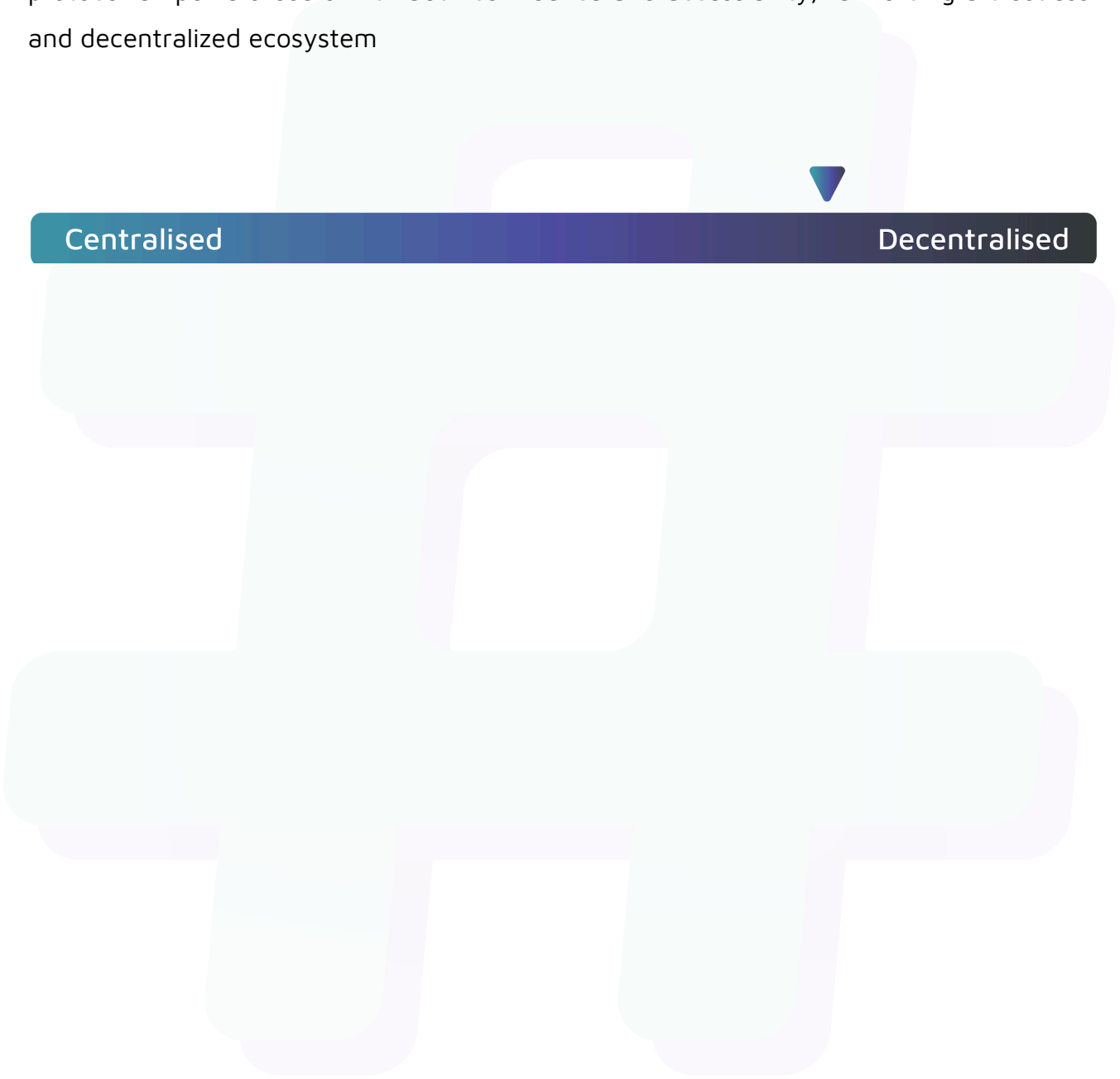
Update the P2ST documentation to explicitly explain Group ID and Group Amount encoding in the Script PubKey and add examples in docs.

Status

Resolved

Centralisation

The Nebula project prioritizes security and utility while maintaining a decentralized framework. Its design ensures that core functionality remains resilient and reliable. The protocol empowers users with both confidence and accessibility, reinforcing a trustless and decentralized ecosystem



Centralised

Decentralised

Conclusion

After Hashlock's analysis, the Nebula project seems to have a sound and well-tested code base, now that our vulnerability findings have been resolved. Overall, most of the code is correctly ordered and follows industry best practices. The code is well commented on as well. To the best of our ability, Hashlock is not able to identify any further vulnerabilities.

Our Methodology

Hashlock strives to maintain a transparent working process and to make our audits a collaborative effort. The objective of our security audits is to improve the quality of systems and upcoming projects we review and to aim for sufficient remediation to help protect users and project leaders. Below is the methodology we use in our security audit process.

Manual Code Review:

In manually analysing all of the code, we seek to find any potential issues with code logic, error handling, protocol and header parsing, cryptographic errors, and random number generators. We also watch for areas where more defensive programming could reduce the risk of future mistakes and speed up future audits. Although our primary focus is on the in-scope code, we examine dependency code and behaviour when it is relevant to a particular line of investigation.

Vulnerability Analysis:

Our methodologies include manual code analysis, user interface interaction, and white box penetration testing. We consider the project's website, specifications, and whitepaper (if available) to attain a high-level understanding of what functionality the smart contract under review contains. We then communicate with the developers and founders to gain insight into their vision for the project. We install and deploy the relevant software, exploring the user interactions and roles. While we do this, we brainstorm threat models and attack surfaces. We read design documentation, review other audit results, search for similar projects, examine source code dependencies, skim open issue tickets, and generally investigate details other than the implementation.

Documenting Results:

We undergo a robust, transparent process for analysing potential security vulnerabilities and seeing them through to successful remediation. When a potential issue is discovered, we immediately create an issue entry for it in this document, even though we have not yet verified the feasibility and impact of the issue. This process is vast because we document our suspicions early even if they are later shown to not represent exploitable vulnerabilities. We generally follow a process of first documenting the suspicion with unresolved questions, and then confirming the issue through code analysis, live experimentation, or automated tests. Code analysis is the most tentative, and we strive to provide test code, log captures, or screenshots demonstrating our confirmation. After this, we analyse the feasibility of an attack in a live system.

Suggested Solutions:

We search for immediate mitigations that live deployments can take and finally, we suggest the requirements for remediation engineering for future releases. The mitigation and remediation recommendations should be scrutinised by the developers and deployment engineers, and successful mitigation and remediation is an ongoing collaborative process after we deliver our report, and before the contract details are made public.

Disclaimers

Hashlock's Disclaimer

Hashlock's team has analysed these smart contracts in accordance with the best industry practices at the date of this report, in relation to: cybersecurity vulnerabilities and issues in the smart contract source code, the details of which are disclosed in this report, (Source Code); the Source Code compilation, deployment, and functionality (performing the intended functions).

Due to the fact that the total number of test cases is unlimited, the audit makes no statements or warranties on the security of the code. It also cannot be considered as a sufficient assessment regarding the utility and safety of the code, bug-free status, or any other statements of the contract. While we have done our best in conducting the analysis and producing this report, it is important to note that you should not rely on this report only. We also suggest conducting a bug bounty program to confirm the high level of security of this smart contract.

Hashlock is not responsible for the safety of any funds and is not in any way liable for the security of the project.

Technical Disclaimer

Smart contracts are deployed and executed on a blockchain platform. The platform, its programming language, and other software related to the smart contract can have their own vulnerabilities that can lead to attacks. Thus, the audit can't guarantee the explicit security of the audited smart contracts.

About Hashlock

Hashlock is an Australian-based company aiming to help facilitate the successful widespread adoption of distributed ledger technology. Our key services all have a focus on security, as well as projects that focus on streamlined adoption in the business sector.

Hashlock is excited to continue to grow its partnerships with developers and other web3-oriented companies to collaborate on secure innovation, helping businesses and decentralised entities alike.

Website: hashlock.com.au

Contact: info@hashlock.com.au



#hashlock.